

Web Application Security Assessment — Rescan

newsouthtechnologies.com • Rev. 2

Follow-up re-test to verify remediation of the prior assessment and identify any new exposure.

CONFIDENTIAL — RESTRICTED DISTRIBUTION. Identifies live exposure and exact URLs. Do not publish or commit to the website repository.

Field	Detail
Prepared for	New South Technologies — Co-Managing Partners
Assessed by	Senior Penetration Tester
Rescan date	July 26, 2026
Baseline	Web Application Security Assessment, Rev. 1 (July 26, 2026)
Method	Unauthenticated live requests against the production site, including cache-bypass probes (query-string busting) to distinguish origin content from cached content; behavioral probing of the /api/forms/careers Pages Function.
Tooling limitation	HTTP response headers could not be read with the available fetch tooling; header-level findings are marked for external confirmation (e.g., securityheaders.com / curl -I).
Classification	Confidential — restricted

1. Executive Summary

Real progress since Rev. 1. The internal document-template kit (NDA, MSA, SOW, letterhead, email signature, business card, etc.) and the internal strategy notes are no longer present at the origin — requests now fall through to the site's catch-all instead of returning the files. The careers Pages Function is deployed and intercepting its route (the hardened handler — origin-locked CORS, KV rate limiting, magic-byte file validation, and an early size guard — is live), and the ROI calculator now carries its methodology disclaimer. That closes or materially reduces most of the prior high-severity items at the source.

One critical exposure remains, and it is subtle. The personal-data file /Documents.txt was removed from the origin — a cache-bypassing request (with a query string) now returns the catch-all page — but the canonical URL <https://newsouthtechnologies.com/Documents.txt> still serves the family biography, including private individuals' names, from Cloudflare's edge cache. The content was deleted but the cache was never purged, so the sensitive data is still publicly retrievable at its original address. The same class of risk applies to any other removed-but-previously-cached file.

Net: the remediation was ~80% effective but is not complete until the CDN cache is purged and the security-header deployment is confirmed. Purging the cache is now the single highest-priority action.

2. Status Since the Previous Assessment

ID	Item	Status	Evidence / note
F-1	Personal PII file (/Documents.txt)	Critical	Removed from origin but STILL served from stale Cloudflare cache at the canonical URL. Confirmed: cache-busting query returns catch-all; plain URL returns the biography.

ID	Item	Status	Evidence / note
F-2	Internal template kit (documents/Templates/*)	Fixed	Removed from origin — /documents/Templates/nda-mutual.html now returns the catch-all, not the template.
—	research_notes.md	Fixed	Removed from origin (catch-all).
F-9	No cache purge on content removal (NEW)	High	Systemic: deleting files does not evict Cloudflare's cache; removed sensitive content lingers at the edge (see F-1).
F-4	HTTP security headers	Unconfirmed	Corrected “_headers” shipped in the deployed commit, but response headers can't be read with current tooling — confirm externally.
F-5	Careers upload hardening	Improved	Magic-byte validation + early size guard deployed; endpoint live. AV scan, Azure retention, KV/secret binding still pending.
M-4	ROI methodology disclosure	Fixed	“Illustrative estimate only ...” disclaimer confirmed live on the homepage.
F-7	Soft-404 returns HTTP 200	Open	Unknown paths still return 200 with the homepage rather than a 404.

3. Current Findings

F-1 (residual) Personal PII still served from stale CDN cache

Severity: **Critical**

The origin no longer hosts /Documents.txt (a cache-bypassing request returns the catch-all), yet the canonical URL still returns the full personal biography — private family names and lineage — because Cloudflare's edge cache retains the previously-served copy. Any visitor or crawler hitting the plain URL still receives the PII. Removal without a cache purge is not remediation.

Remediation: purge the Cloudflare cache now (Dashboard → Caching → Purge Everything, or purge the specific URLs /Documents.txt, /CLAUDE.md, /QA-Peer-Review-Report.html, and the former /documents/Templates/* paths). Then re-verify by fetching each canonical URL (no query string); each must return a 404/catch-all. Because the file also existed in Git history, treat the names as disclosed and remove the file from history if the repository is or becomes public.

F-9 (new) No cache invalidation on content removal

Severity: **High**

Root cause behind F-1: deleting a file from the repository and redeploying does not evict Cloudflare's edge cache, so sensitive content can remain publicly retrievable at the edge after it is “removed.” Remediation: add a cache purge to the deployment process (Cloudflare Pages can purge on deploy, or use the API), set explicit Cache-Control with a short max-age for text/markdown/document responses, and keep sensitive material out of the deploy root entirely so it is never cached in the first place.

F-4 HTTP security headers — confirm deployment

Severity: **Medium**

The corrected “_headers” file (with CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy) was included in the deployed commit, so headers are likely now applied — but this could not be verified with the fetch tooling used for the rescan. Action: confirm externally (securityheaders.com or curl -sI https://newsouthtechnologies.com/); ensure the misnamed “_headers.txt” was deleted so only the active “_headers” remains.

F-5 Careers pipeline — remaining hardening

Severity: **Medium**

Deployed and improved: the function intercepts its route, and magic-byte content validation plus an early Content-Length guard are in place (verified in code and by behavior). Still outstanding: server-side anti-virus scanning of stored resumes, enforced retention via an Azure Blob lifecycle policy, binding the Cloudflare KV namespace and the Azure/SendGrid secrets, and restricting PII written to logs. Until the secrets/KV are bound, submissions may fail or fall back to per-isolate rate limiting.

F-7 Soft-404 returns HTTP 200

Severity: **Low**

Confirmed still present: arbitrary unknown paths (e.g., /.git/config, /nonexistent) return HTTP 200 with the homepage instead of a 404. This aids automated content-discovery and harms SEO. Configure a proper 404 response/page.

Carried forward (unchanged this cycle)

- **Third-party / SRI (F-6):** external scripts (Cookiebot, Google Fonts) still load without Subresource Integrity; lead forms still egress PII to Formsprees.
- **Config recon (F-8):** if /wangler.toml is still deployed it discloses infra intent; keep it (and any config) out of the published output.

- **Email anti-spoofing:** SPF/DKIM/DMARC (Appendix A) — DNS actions that could not be validated remotely; still recommended to blunt impersonation of the (now-removed but historically exposed) brand assets.
- **Non-security items from the compliance review:** federal identifiers still show “Available on request”; SAM / 8(a) / SDVOSB / SOC 2 / WCAG claims still require substantiation.

4. Prioritized Actions (this cycle)

#	Action	Why
1	Purge the Cloudflare cache (all, or the specific URLs) and re-verify /Documents.txt (and CLAUDE.md, QA-Peer-Review-Report.html) return 404 at the canonical URL.	Critical
2	Add cache purge to the deploy process; set short Cache-Control on text/doc responses; keep sensitive files out of the deploy root.	High
3	Confirm security headers are live (external header scan); delete “_headers.txt”.	Medium
4	Finish careers hardening: bind KV + Azure/SendGrid secrets; add AV scan; enforce Azure retention; trim PII from logs.	Medium
5	Configure a proper 404; add SRI; stand up SPF/DKIM/DMARC (Appendix A).	Low

5. What Improved

- **Impersonation kit removed** — the NDA/MSA/SOW/letterhead/email-signature/business-card templates no longer serve from the origin.
- **Internal notes removed** — research_notes.md no longer serves from the origin.
- **Careers function hardened & deployed** — origin-locked CORS, KV rate limiting, magic-byte + size validation are live at the source.
- **ROI claim disclaimed** — the calculator now states its figures are illustrative.

Appendix A — Email Anti-Spoofing (SPF / DKIM / DMARC)

Because on-brand templates were historically exposed and leadership names are public, forged NST email remains a realistic threat. Publish SPF + DKIM + DMARC on the domain's DNS (values depend on your mail provider).

- **SPF** (one TXT at the root, hard fail): Google Workspace `v=spf1 include:_spf.google.com -all` · Microsoft 365 `v=spf1 include:spf.protection.outlook.com -all`. Add includes for every legitimate sender; keep to one record, ≤ 10 lookups.
- **DKIM**: enable signing in your mail provider and publish the provider's public-key TXT at the given selector (e.g., `google._domainkey / selector1._domainkey`). Rotate periodically.
- **DMARC** (TXT at `_dmarc`): start `v=DMARC1; p=none; rua=mailto:dmarc@newsouthtechnologies.com; fo=1; adkim=s; aspf=s` — review reports 2–4 weeks — then tighten to `p=quarantine` and finally `p=reject`; `pct=100`. Only `p=reject` causes receivers to drop forgeries.
- **Reinforce**: BIMI, MTA-STS + TLS-RPT, a `/.well-known/security.txt`, and a published official careers URL (NST never requests resumes/clearance details elsewhere).

Methodology & Responsible Handling

Authorized, non-destructive re-test using unauthenticated HTTP requests, including cache-bypass probes to separate origin state from cached responses, plus behavioral probing of the careers Pages Function. Response headers were not readable with the tooling used and are flagged for external confirmation. This report contains exploitation-relevant detail and exact URLs; keep it confidential, need-to-know, and out of the website repository.

End of rescan report.